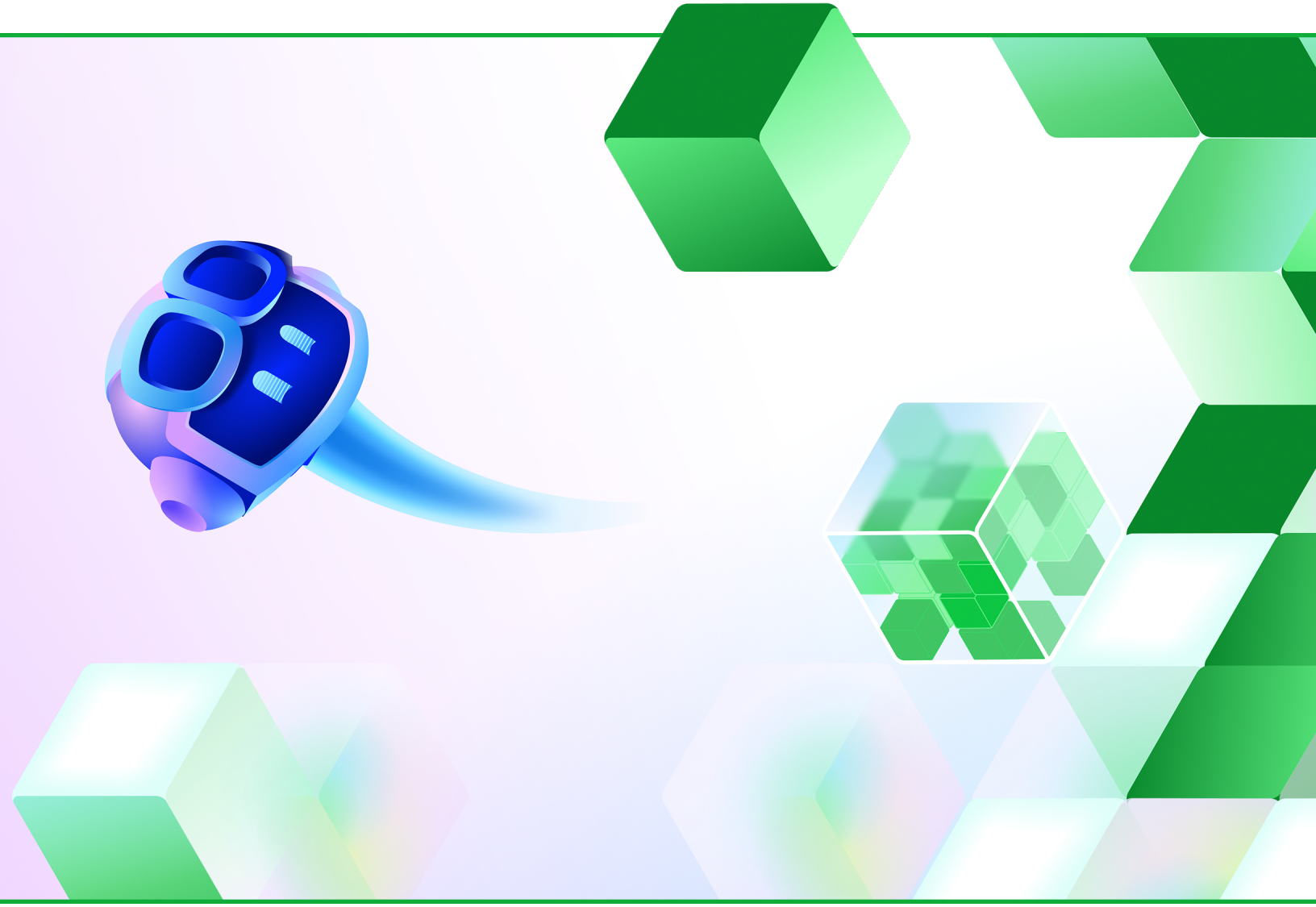
O guia corporativo para DevSecOps da plataforma IA



ESCRITO PELO GITHUB COM ❤

Prefácio

DevSecOps é uma prática e metodologia que visa tornar o recurso Shift-Left uma realidade, integrando a segurança a cada etapa do SDLC (ciclo de vida de desenvolvimento de software). Basicamente, a DevSecOps alinha o trabalho de segurança e, em alguns casos, as funções de engenharia e segurança que historicamente seria feito de maneira separada e direta no fluxo de trabalho de DevOps. Como resultado, a DevSecOps reduz o custo e o impacto das violações de segurança e permite que as equipes enviem software seguro mais rapidamente. Na verdade, o relatório Cost of a Data Breach da IBM de 2023 cita uma economia de custos de USD 1,68 milhão para organizações com alta adoção de DevSecOps em comparação com aquelas com baixa ou nenhuma adoção.

O desafio de usar o recurso Shift-Left

Embora os profissionais de segurança tenham sido incentivados a usar o recurso Shift-Left na última década, o mesmo relatório da IBM constatou que apenas 33% das violações foram identificadas pela equipe de segurança interna das organizações. Isso mostra o grau de dificuldade da incorporação da segurança ao SDLC. Para fazer Shift-Left, as organizações precisam de ferramentas que não só possam encontrar vulnerabilidades de segurança antes que o código entre em produção, mas também possam se integrar perfeitamente ao SDLC.

Como a IA pode ajudar a tornar o Shift-Left uma realidade

Quando usada de maneira eficaz, a IA pode ajudar a evitar que vulnerabilidades sejam escritas, fornecer sugestões de código seguro que os desenvolvedores poderão testar e refinar e fornecer contexto sobre possíveis vulnerabilidades, tudo no fluxo de trabalho típico do desenvolvedor.

Como este guia ajudará a criar uma estratégia de DevSecOps da plataforma IA

O relatório da IBM concluiu que a DevSecOps foi o principal fator que ajudou as empresas a reduzir o custo médio de uma violação de dados. Já escrevemos sobre DevSecOps e práticas recomendadas, além de dicas para ajudar as organizações a integrar práticas de segurança durante todo o SDLC. Agora, vamos discutir como a IA pode ajudar a aliviar os principais desafio que as organizações enfrentam ao implementar uma estratégia DevSecOps: corrigindo os riscos com eficiência, atendendo à crescente demanda por inteligência de segurança e mantendo a conformidade com os padrões regulatórios mais recentes.

O que vem incluído

2 Prefácio

4 Os três principais desafios para implementar a DevSecOps e como a IA pode resolvê-los

11 Implemente sua estratégia de DevSecOps com a IA

12 Integrando a segurança da plataforma IA em cada etapa do SDLC: um diagrama

Os três principais desafios para implementar a DevSecOps e como a IA pode resolvê-los

O alto índice de adoção de DevSecOps vem com uma alta quantidade de benefícios de redução de custos, mas integrar verdadeiramente a segurança ao SDLC é algo desafiador, pois não se trata apenas de integrar ferramentas de segurança a fluxos de trabalho existentes.

A rápida adoção da IA no desenvolvimento de software apresenta uma oportunidade para reduzir o atrito na implementação de DevSecOps. **Até 2027, espera-se que 50% dos engenheiros de software corporativo usem ferramentas de codificação com tecnologia de Machine Learning,** de acordo com a Gartner. A adoção dessas ferramentas solidificará o uso da IA em todo um fluxo de trabalho de DevSecOps, abrindo caminho para práticas de segurança mais eficientes e proativas.

Vamos analisar os principais desafios da implementação de uma estratégia de DevSecOps, discutir possíveis causas raiz e, em seguida, explorar soluções de IA e automação que podem ajudar as organizações a adotar uma postura de segurança proativa.

Desafio 1: Corrigir riscos à segurança na cadeia de suprimento de software

O investimento financeiro por si só não corrige o risco à segurança. As taxas de correção permaneceram estagnadas ao longo dos anos, apesar do aumento do investimento em segurança. A Gartner prevê que 45% das organizações globais serão afetadas de alguma maneira por um ataque da cadeia de suprimento até 2025.

O abuso de aplicações e credenciais está no centro de 86% de todas as violações de dados, de acordo com o 2023 Verizon Data Breach Investigation Report. Além disso, de acordo com o relatório da IBM, as violações de março de 2022 a 2023 que começaram com credenciais roubadas ou comprometidas levaram mais tempo para serem resolvidas (exatamente 328 dias). Além disso, para cumprir prazos, 81% dos desenvolvedores sentem a pressão para lançar códigos vulneráveis, conforme citado em um white paper da Osterman Research.

A chave para se proteger contra abuso de credenciais? Adote uma estratégia de DevSecOps que garanta que suas plataformas sejam seguras por padrão por meio de proteções como autenticação multifatorial e controles de segurança automatizados. A DevSecOps é o principal fator que ajuda as empresas a reduzir o custo médio de uma violação de dados, de acordo com o relatório da IBM.

45%

(estimado) das organizações globais serão afetadas de alguma maneira por um ataque da cadeia de suprimento até 2025.

86%

de todas as violações de dados ocorreram por meio de abusos de aplicações e credenciais em 2023.

Nº 1

Uma estratégia de DevSecOps é o principal fator que ajuda as empresas a reduzir o custo médio de uma violação de dados.

Como a IA e a automação podem agilizar a correção

A ideia não é substituir as medidas de segurança pela IA. Em vez disso, as organizações podem usar a IA para reduzir o atrito e ajudar a aumentar seus programas de segurança. Vejamos alguns recursos de IA e automação que os líderes de engenharia inovadores consideram ao selecionar uma plataforma de DevSecOps:

- **Automatizar alertas de correção e sugerir correções de códigos.** Um recurso como uma correção automática de verificação de código pode sugerir uma correção de código gerada por IA com alertas de vulnerabilidade em uma pull request.
- **Proteger segredos não estruturados.** Em vez de verificar segredos identificados e protegidos somente em relação a padrões de parceiros predefinidos, um recurso como verificação de segredos também pode detectar senhas e outros segredos genéricos ou não estruturados no código.
- **Geração automática de padrões personalizados.** A verificação de segredos também pode usar a IA para gerar automaticamente padrões personalizados e detectar tipos de token únicos de uma organização.

Você sabia?

Os recursos de segurança automatizados podem verificar o código, mas a postura de segurança de uma organização pode mudar dependendo da posição desse recurso em seu SDLC. Por exemplo, o código poderá ser verificado depois de publicado e acionar um alerta de segurança se um segredo vazado for detectado. Por outro lado, um recurso de proteção de push pode verificar segredos antes que o código seja enviado ao repositório de uma organização.

Uma plataforma que oferece suporte a recursos de segurança proativos, como a proteção de push, pode evitar milhares de vazamentos de segredos. Por exemplo, o recurso de proteção de push do GitHub Advanced Security evitou mais de 11 mil vazamentos de segredos em 100 tipos de segredos de abril a dezembro de 2022, de acordo com dados internos.

Desafio 2: Atender à demanda urgente por inteligência em segurança

O mundo precisa de **mais 4 milhões de profissionais de segurança**, de acordo com o estudo de 2023 sobre equipes de trabalho do ISC2 (International Information System Security Certification Consortium). O aumento da demanda é a proporção de desenvolvedores para profissionais de segurança: **para cada 100 desenvolvedores, uma organização tem um pesquisador de segurança.** Se tantos códigos forem produzidos por um grande número de desenvolvedores sem profissionais de segurança suficientes para verificá-los, as vulnerabilidades poderão ser negligenciadas, causando possíveis violações de segurança.

Além disso, com a expectativa de que mais engenheiros de software corporativo usem ferramentas de codificação de IA, provavelmente haverá mais código para revisão, aumentando ainda mais a demanda por profissionais de segurança. Mas as organizações podem se posicionar para acompanhar o novo cenário, implementando práticas de segurança de IA em sua estratégia de segurança.

1

Especialista de segurança de aplicações

100

Desenvolvedores de software

Como a IA e a automação podem aumentar a inteligência de segurança

- **A IA pode ajudar os desenvolvedores a escrever códigos seguros desde o início.** As ferramentas de codificação de IA podem ajudar os desenvolvedores a tomar boas decisões de segurança no fluxo de criação de código, mesclando segurança e engenharia.
- **A IA pode aumentar os esforços manuais de caça às ameaças.** Por exemplo, os bancos de dados de consultoria frequentemente incluem exposições de vulnerabilidades comuns e consultorias de segurança Open Source selecionadas por pesquisadores de segurança. Plataformas de segurança robustas também podem ter uma comunidade de caçadores de recompensas, além de uma equipe de resposta a incidentes de segurança que monitora ativamente ataques ao registro de dados e às fontes de telemetria. A IA pode acelerar esses esforços, permitindo que os pesquisadores de segurança façam pesquisas mais rapidamente, ajudando-os a detectar novas vulnerabilidades e automatizando os processos manuais.

- **A IA pode fornecer aos desenvolvedores orientações e treinamentos de segurança.** Quando os desenvolvedores recebem um alerta de segurança, eles podem usar produtos como ferramentas de codificação de IA diretamente em seu espaço de trabalho para entender o que há de errado. Assim, em vez de sair de seu espaço de trabalho para procurar uma resposta na Web, os desenvolvedores são informados sobre os problemas de segurança no fluxo da codificação. Os desenvolvedores também podem criar familiaridade com conceitos de segurança usando ferramentas de IA para gerar exemplos de vulnerabilidade adaptados à sua base de código. Essa experiência prática de aprendizagem permite que os desenvolvedores entendam como um problema de segurança se manifesta no código.

Três etapas para transformar a inteligência de segurança coletiva em resultados em grande escala

Em média, 90% das organizações de todo o mundo usam software Open Source (OSS), de acordo com o relatório de 2023 Global Spotlight da Linux Foundation. Além disso, a Linux Foundation constatou que 72% das empresas que planejam implementar uma iniciativa de OSPO ou OSS esperam fazer isso nos próximos 12 meses.

Proteger o OSS é um problema coletivo e uma responsabilidade coletiva. Isso significa que um grupo grande e diversificado de desenvolvedores, organizações e indivíduos que dependem de software, mantenedores de Open Source e especialistas em segurança se tornam stakeholders. Por que isso é importante? **Open source cria um pool maior de inteligência de segurança para extração.**

Veja a seguir três dicas para transformar a inteligência de segurança coletiva em resultados em grande escala.

1. **Forneça às equipes de engenharia aprendizado e desenvolvimento práticos de segurança.** Conforme mencionado acima, um programador de pares de IA pode ajudar os desenvolvedores a aprender mais conceitos de segurança gerando exemplos de vulnerabilidades adaptados para códigos específicos. Uma sessão de treinamento interativa gratuita, como o Secure Code Game, também ensina os desenvolvedores a identificar e corrigir padrões vulneráveis em códigos reais, integrar a segurança aos fluxos de trabalho e entender os alertas de segurança gerados em relação ao código.

2. **Use um banco de dados público de consultorias para proteger repositórios privados.** Os líderes de engenharia devem selecionar uma plataforma que utilize a inteligência de segurança de um banco de dados consultivo público. Tais plataformas podem gerar notificações de alerta quando um relatório consultivo é publicado sobre uma vulnerabilidade ou um malware que afeta o código de uma organização.
3. **Acelere a compreensão e a modelagem de pacotes do OSS com a IA.** Há milhares de pacotes no OSS que frequentemente contêm APIs que podem ser desconhecidas para os desenvolvedores. Mas entender e modelar esses pacotes é o que mantém o ecossistema do OSS seguro. Em vez de modelar APIs manualmente, as equipes de segurança e engenharia podem usar ferramentas de IA para identificar mais pacotes e detectar mais vulnerabilidades. Saiba como uma equipe de pesquisadores de segurança do GitHub descobriu uma nova vulnerabilidade usando a modelagem de IA.

GitHub: uma plataforma de desenvolvimento da plataforma IA para criar, escalar e fornecer software seguro

Mais de 100 milhões de desenvolvedores e mais de 90% das empresas da Fortune 100 usam o GitHub para criar, manter e colaborar em projetos de software. Da capacitação dos desenvolvedores com as mais recentes inovações em IA à incorporação da segurança diretamente ao fluxo de trabalho do desenvolvedor, o GitHub fornece às equipes de engenharia tudo o que elas precisam para criar e fornecer software seguro.

Saiba por que as equipes escolhem o GitHub

Desafio 3: Cumprir o número cada vez maior de padrões regulatórios e de conformidade

As organizações estão enfrentando crescentes requisitos de conformidade e regulamentação que garantem a segurança e a confidencialidade dos dados e usuários. Esses padrões foram

criados para minimizar o risco de violações graves de dados e ciberataques. Portanto, a demonstração de conformidade garante que clientes e empresas estão comprometidos com a proteção de dados pessoais.

Confira uma visão geral desses diversos padrões regulatórios:

Nome	Padrão
Decisão executiva sobre IA segura e confiável	Lançada em outubro de 2023 pelo governo de Biden, a decisão fornece um roteiro para que os EUA possam criar, desenvolver e implantar a IA. Ela enfatiza o desenvolvimento e o uso de sistemas de IA confiáveis. Ela também incentiva parcerias entre o governo federal, o setor privado, o setor acadêmico e outros stakeholders no desenvolvimento e na implantação da IA.
Decisão executiva para melhorar a segurança cibernética do país	Assinada em maio de 2021 pelo governo Biden, essa decisão executiva exige o endurecimento das práticas de segurança cibernética, bem como o desenvolvimento de padrões, diretrizes e procedimentos que estabelecem níveis mais altos de segurança da cadeia de fornecimento de software.
Health Insurance Portability and Accountability Act – HIPAA (Lei de portabilidade de seguros de saúde e responsabilidade)	Essa lei dos EUA exige que todas as empresas do país que gerenciam dados de saúde protegidos tenham acesso eletrônico seguro a dados de saúde e se mantenham em conformidade com os regulamentos de privacidade estabelecidos pelo Departamento de Saúde e Serviços Sociais dos EUA.
GDPR (Regulamento Geral sobre a Proteção de Dados)	Essa regulamentação da União Europeia (EU) estabelece regras rígidas sobre como as empresas coletam e gerenciam dados pessoais e exige que as empresas protejam os dados pessoais e a privacidade dos cidadãos e residentes da União Europeia em transações que ocorrerem dentro dos estados-membros da União Europeia (mesmo que a empresa não esteja na União Europeia).
Payment Card Industry Data Security Standard (Padrão de segurança de dados da indústria de cartões de pagamento, PCI DSS)	Administrado pelo PCI Security Standards Council, ele é um conjunto global de padrões de segurança da informação para organizações que gerenciam cartões de crédito de marcas de grandes bandeiras.

Como a IA e a automação podem simplificar a conformidade

A conformidade com esses padrões cria uma vantagem competitiva. Portanto, as organizações precisam de soluções eficazes que possam avaliar e manter a conformidade e fornecer relatórios detalhados de auditorias. Confira as **principais tarefas de conformidade que as ferramentas de segurança devem facilitar e como a IA e a automação podem ajudar a simplificar o processo:**

- **Observabilidade.** Um painel que proporciona visibilidade de nível macro de um ambiente é essencial para avaliar a integridade geral e as tendências da postura de segurança de uma organização. Ao facilitar a localização de alertas no SDLC, um painel auxilia no rastreamento, correção e prevenção de riscos. Os painéis também podem destacar quais equipes são mais eficientes na correção e quais tipos de vulnerabilidades estão sendo evitados com os recursos de IA e automação, como a proteção de push para verificação de segredos. Além disso, habilitar a verificação da codificação por padrão nos repositórios da sua organização permite o monitoramento automatizado das bases de código.
- **Geração de relatórios.** As melhores soluções ajudam as equipes a automatizar a conformidade com os padrões da indústria e fornecem relatórios detalhados sobre as vulnerabilidades e os problemas de conformidade que podem ser compartilhados com os auditores. Plataformas que fornecem acesso fácil a logs de auditoria detalhados, relatórios de conformidade e integrações dão suporte às organizações em seus esforços de conformidade internos e externos.
- **Gerenciamento de conformidade.** Certificações da International Organization for Standardization (ISO), como ISO 27701 e ISO 27018, e da Cloud Security Alliance, como STAR (Security, Trust & Assurance Registry), dão suporte a requisitos de proteção de dados em desenvolvimento de software, garantem que os desenvolvedores sigam as melhores práticas de proteção de dados em serviços de nuvem e avaliam a segurança dos serviços de nuvem. Ao alcançar e manter essas certificações, você verifica o compromisso com a manutenção de altos padrões de proteção e segurança de dados.

Selecionar uma plataforma com IA nativa e recursos de segurança automatizados pode ajudar as organizações a atender a esses altos padrões, criando uma experiência positiva de DevSecOps. Essas ferramentas podem agilizar as correções ao priorizar alertas de segurança com regras de triagem personalizadas e automatizadas, permitir que as organizações detectem dependências inseguras antes de serem introduzidas em um ambiente e manter as organizações informadas sobre licenças de dependência, alterações, uso de projetos e vulnerabilidades.

Melhore sua postura de segurança com o GitHub Advanced Security

Utilizando recursos do GitHub Advanced Security como revisões de dependências e verificação de códigos e segredos, as organizações podem gerenciar melhor as bibliotecas e dependências de terceiros, otimizar os fluxos de trabalho com a integração da segurança diretamente ao SDLC e manter a conformidade com várias regulamentações da indústria.

Proteja seus códigos hoje mesmo

Implemente sua estratégia de DevSecOps com a IA

Por que as organizações precisam proteger o fluxo de trabalho do desenvolvedor e adotar o DevSecOps? Porque o software começa com o código. As organizações que migram para a esquerda e integram profundamente a segurança a cada etapa do SDLC economizam USD 1,68 milhões em custos em comparação com as organizações com baixa ou nenhuma adoção de DevSecOps.

Entretanto, conforme discutido acima, há desafios para implementar uma estratégia de DevSecOps bem-sucedida, incluindo baixas taxas de correção, uma demanda crescente por profissionais de segurança e a necessidade de atender aos crescentes padrões regulatórios e de conformidade.

É aqui que a IA e a automação podem ajudar a transformar a DevSecOps em realidade:

- **Acelere a correção.** As ferramentas de codificação de IA podem ajudar os desenvolvedores a escrever códigos mais seguros desde o início. Já as ferramentas de segurança podem automatizar os alertas de correção. Quando combinados, os alertas podem incluir sugestões de correção de código geradas por IA, simplificando o fluxo de trabalho de correção e melhorando a produtividade do desenvolvedor.
- **Aumente a inteligência de segurança coletiva** permitindo que os pesquisadores de segurança usem a IA para fazer pesquisas com mais rapidez e detectar novas vulnerabilidades.
- **Melhore os treinamentos de segurança dos desenvolvedores** com um programador de pares de IA que permite que os desenvolvedores sejam informados sobre problemas de segurança no fluxo da codificação e com exemplos práticos adaptados para sua base de código.
- **Melhore o monitoramento, os relatórios e o gerenciamento de conformidade.** As ferramentas de IA e automação podem facilitar a obtenção de logs de auditoria e a priorização de alertas de segurança para que as organizações possam atender e manter altos padrões de conformidade, melhorando a experiência de DevSecOps.

As ferramentas de segurança de IA e automação podem desempenhar um papel crucial para ajudar as organizações a proteger o código na mesa do desenvolvedor. O resultado é a redução dos riscos, detecção, correção e implantações mais rápidas de softwares mais seguros.

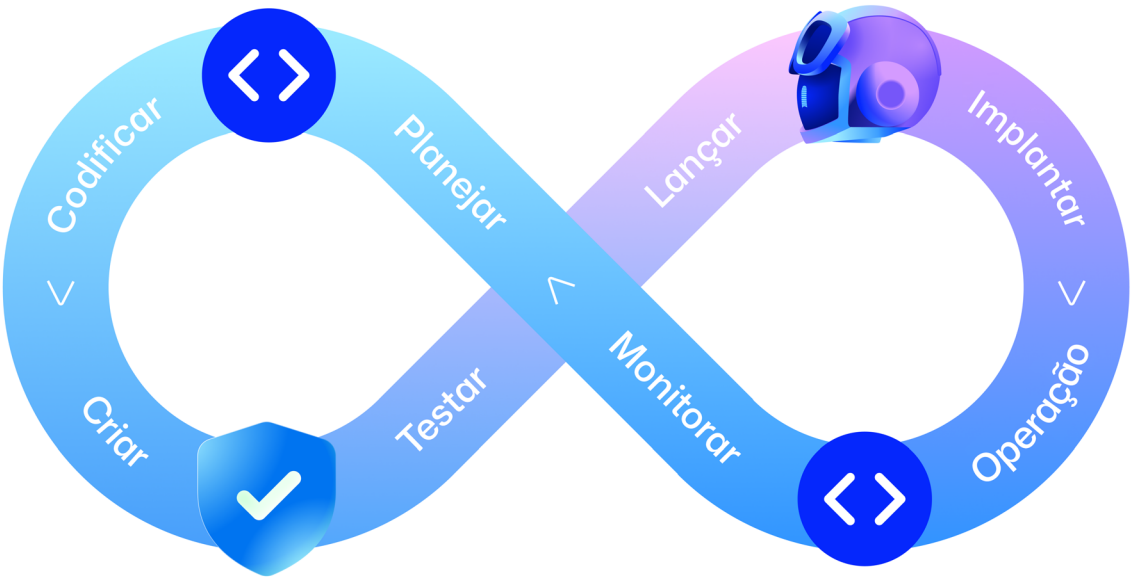
O GitHub está aqui para ajudar.

Com o GitHub Advanced Security, as organizações podem melhorar sua postura de segurança, otimizar os fluxos de trabalho e manter a conformidade proativamente com várias regulamentações e padrões. Seus recursos de segurança da plataforma IA também podem fornecer às equipes de engenharia uma experiência de DevSecOps sem atrito, ou seja, as empresas fornecem produtos de forma mais segura e rápida.

Saiba mais sobre o GitHub Advanced Security

Integrando a segurança da plataforma IA em cada etapa do SDLC: um diagrama

A integração da segurança durante todo o SDLC pode ajudar a reduzir o atrito ao implementar uma estratégia de DevSecOps. O diagrama abaixo mostra como a plataforma do GitHub fornece um conjunto de ferramentas de segurança, IA e automação, além de recursos para melhorar a experiência de DevSecOps.



Planejar

Juntos, o GitHub Issues e o GitHub Projects oferecem um conjunto de ferramentas integrado para planejar, organizar, acompanhar e gerenciar seus projetos diretamente no GitHub, simplificando qualquer processo de gerenciamento de projetos. Por exemplo, os gerentes de projetos podem criar quadros de projeto do GitHub para automatizar o acompanhamento de problemas relacionados à segurança e solicitações pull.

Codificar

Ao recomendar práticas seguras, detectar erros com antecedência e minimizar erros de codificação comuns, o GitHub Copilot pode ajudar os desenvolvedores a escrever códigos mais seguros desde o início. É importante observar que a IA está lá para ajudar na escrita de código e não deve substituir revisões completas de segurança e melhores práticas de codificação.

Criar

O Codespaces fornece aos desenvolvedores ambientes de criação pré-configurados e consistentes que são projetados para serem seguros por padrão.

Testar

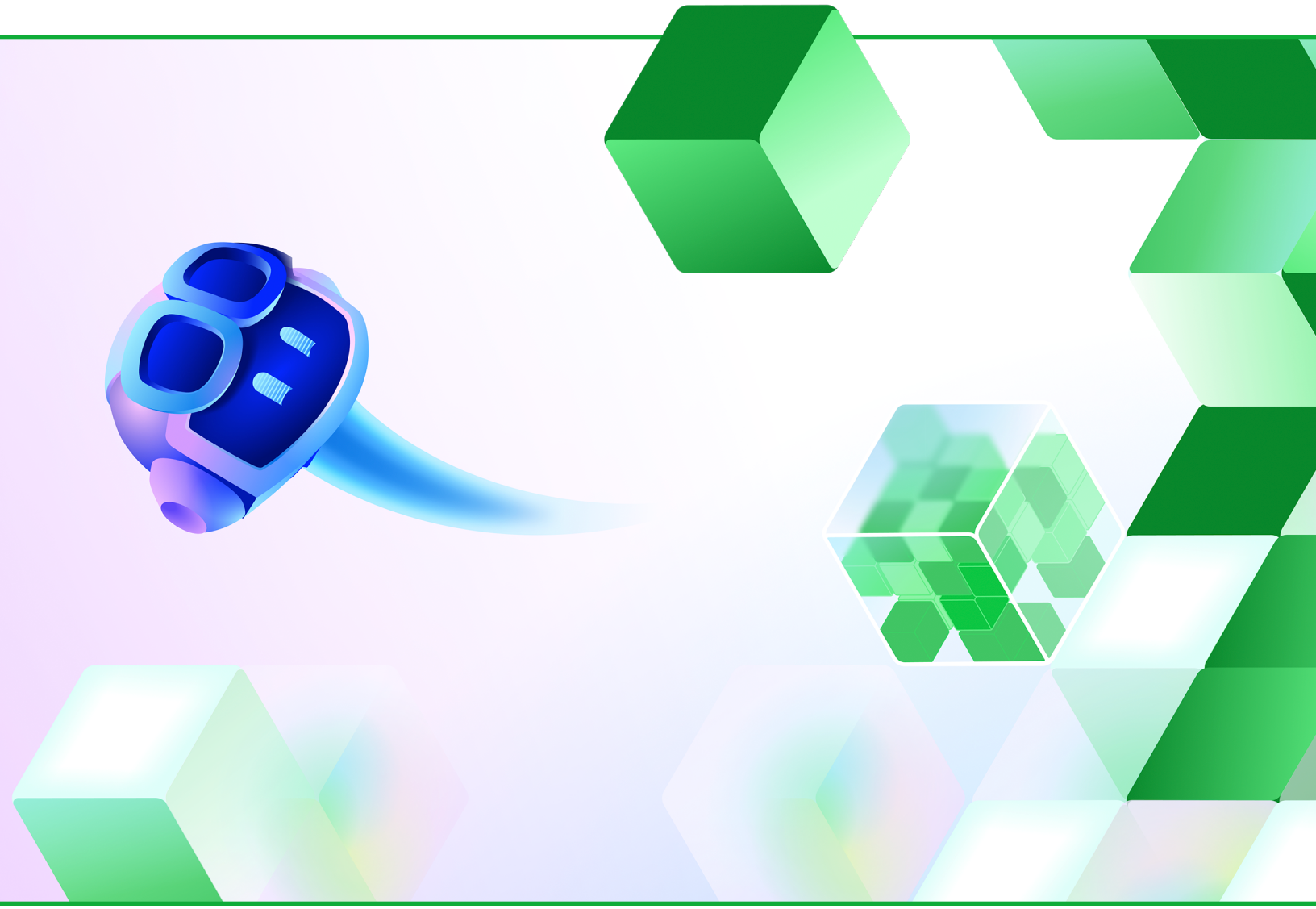
O GitHub Advanced Security e o GitHub Packages podem funcionar juntos para simplificar o processo de testes. Por exemplo, os recursos do GitHub Advanced Security ajudam os desenvolvedores a dissipar preocupações de segurança antes que as alterações de código sejam mescladas, detectar segredos antes que eles sejam enviados aos repositórios e identificar e resolver os possíveis riscos de segurança em suas dependências. Enquanto isso, o GitHub Packages permite que os desenvolvedores hospedem pacotes de software, simplificando a replicação de ambientes em tempo real para testes, melhorando assim a eficácia dos testes.

Lançar

Os recursos do GitHub Advanced Security, como a verificação de segredos, garantem que nenhuma informação confidencial seja incluída no código antes que ele seja implantado. Os desenvolvedores podem usar os recursos de IA da verificação de segredos para ajudar a gerar padrões personalizados para proteger os tipos de segredos únicos de uma organização.

Implantar

O GitHub Actions e o GitHub Mobile fornecem proteções avançadas e recursos de resposta mais rápidos, criando um processo de implantação mais seguro. Por exemplo, as organizações podem usar o GitHub Actions para executar automaticamente linters, ferramentas de análise estática ou verificações de vulnerabilidades de segurança sempre que o código é enviado ou uma pull request é feita. O GitHub Mobile, embora não forneça recursos de implantação, pode ser usado para monitorar o processo de implantação e reagir rapidamente se a intervenção manual for necessária durante a implantação.

Operar e monitorar

Usando ferramentas como o GitHub Actions, o Dependabot e o GitHub Advanced Security permitem que as organizações identifiquem, corrijam e evitem vulnerabilidades de segurança de maneira eficiente e oportuna. Por exemplo, o GitHub Actions pode automatizar a execução de verificações de segurança, bem como processos de implantação para garantir que apenas códigos testados e seguros sejam implantados. A revisão de dependências do GitHub Advanced Security e o Dependabot monitoram a existência de alterações, integração de projetos e vulnerabilidades nas dependências. O recurso de correção automática de verificação de código do GitHub Advanced Security pode fornecer correção de código gerada por IA com alertas de vulnerabilidade em uma pull request.